

Security+ 2.3 · Malicious Updates

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 2.3** —
Malicious Updates (5:45) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: A malicious update (poisoned update) occurs when an attacker compromises the update distribution channel, delivering malware through a trusted vendor's update mechanism. The SolarWinds 2020 attack is a classic example: 18,000 customers downloaded a backdoored update. Defenses include code signing, verifying update origin, and supply chain security.

High-Yield Core Concepts Tested on Exam

- SolarWinds: 18,000 organizations infected via a single poisoned update
- Attack targets the software supply chain and update mechanism
- Defense: code signing, signature verification, origin validation
- Supply chain security is critical for trusted updates

Exam Tips & Classic Scenarios

- 'software update distributes malware' = supply chain attack / poisoned update
- 'trusted vendor update infects many customers' = SolarWinds-style attack

Typical Exam Scenario: 18,000 companies are infected through a trusted vendor's software update, highlighting a supply chain attack (SolarWinds).

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 2.3 — Malicious Updates)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. Compromising a software vendor to reach all of its customers (e.g., SolarWinds):

- A)** Supply chain attack
- B)** Watering hole
- C)** Insider
- D)** Zero-day

2. Corporate scenario (Malicious Updates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'SolarWinds: the classic case — 18k companies via 1 poisoned update.' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Allow shared access among administrators using generic credentials
- D)** Implement the corresponding solution: SolarWinds: the classic case — 18k companies via 1 poisoned update...

3. Corporate scenario (Malicious Updates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Defense: code signing + verification of update origin'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: Defense: code signing + verification of update origin...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

4. Corporate scenario (Malicious Updates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'software update distributes malware' = supply chain attack / poisoned update. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'software update distributes malware' = supply chain attack / poisoned update...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

5. Corporate scenario (Malicious Updates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: '18k companies infected through a trusted vendor update' = supply chain (SolarWinds)'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: '18k companies infected through a trusted vendor update' = supply chain (SolarWinds)...
- D)** Allow shared access among administrators with generic credentials

6. Corporate scenario (Malicious Updates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'SolarWinds: the classic case — 18k companies via 1 poisoned update'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: SolarWinds: the classic case — 18k companies via 1 poisoned update...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

7. Corporate scenario (Malicious Updates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: Defense: code signing + verification of update origin. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: Defense: code signing + verification of update origin...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

8. Corporate scenario (Malicious Updates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'software update distributes malware' = supply chain attack / poisoned update'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: 'software update distributes malware' = supply chain attack / poisoned update...
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

9. Corporate scenario (Malicious Updates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'Scenario: '18k companies infected through a trusted vendor update' = supply chain (SolarWinds).' What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: '18k companies infected through a trusted vendor update' = supply chain (SolarWinds).
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Malicious Updates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 2.3), an analyst evaluates the following technical requirement: 'SolarWinds: the classic case — 18k companies via 1 poisoned update'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Implement the corresponding solution: SolarWinds: the classic case — 18k companies via 1 poisoned update
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Supply chain attack.

✓ **Why it is correct:** A supply chain attack occurs when an adversary compromises a vendor, partner, or software/hardware component to reach the end customers of that vendor. In the SolarWinds case (2020), attackers compromised the build process of the Orion software, inserting malicious code that was distributed as a legitimate update to thousands of customers, including government agencies. This is the classic example of a supply chain attack, as described in SY0-701 objective 2.2 (supply chain threats) and 2.3 (attack vectors). The question describes exactly this scenario: compromising a software vendor to reach all of its customers.

✗ Why the others are wrong:

- *Watering hole:* A watering hole is an attack in which the adversary compromises a legitimate website frequented by a specific group of victims (e.g., an industrial sector site) and inserts malicious code to infect visitors. The goal is to reach users who visit that site, not to compromise a software vendor to distribute malware to all its customers. In a watering hole, the vector is the third-party site visited by victims; in a supply chain attack, the vector is the vendor's own product or update. The question speaks of compromising a software vendor to reach all its customers, which is supply chain, not watering hole.
- *Insider:* An insider threat refers to an individual with authorized access (employee, contractor, partner) who uses that access to cause harm, steal data, or facilitate attacks. The attacker is internal to the organization, not a compromised external vendor. In the SolarWinds case, the attackers were external (APT29) who compromised SolarWinds' supply chain; it is not an insider of SolarWinds or its customers. Therefore, insider does not describe the scenario of compromising a vendor to reach its customers.
- *Zero-day:* A zero-day refers to a vulnerability unknown to the vendor, for which no patch is available. The attack exploits this flaw before it is fixed. Although supply chain attacks may involve zero-days, the concept of zero-day is about the nature of the vulnerability, not about the vector of compromising a vendor to reach customers. In the SolarWinds case, the attack did not rely exclusively on a zero-day; it involved compromising the build process and distributing a malicious update. The question asks for the name of the attack that compromises a vendor to reach all customers, which is supply chain, not zero-day.

2) D — Implement the corresponding solution: SolarWinds: the classic case — 18k companies via 1 poisoned update....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Malicious Updates): SolarWinds: the classic case — 18k companies via 1 poisoned update.

✗ Why the others are wrong:

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

3) B — Implement the corresponding solution: Defense: code signing + verification of update origin....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Malicious Updates): Defense: code signing + verification of update origin. Code signing uses digital signatures to verify the authenticity and integrity of software updates, ensuring they come from a trusted source and have not been tampered with. Verifying the update origin prevents attackers from distributing malicious updates.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and it breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user conduct and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

4) A — Implement the corresponding solution: 'software update distributes malware' = supply chain attack / poisoned update....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Malicious Updates): 'software update distributes malware' = supply chain attack / poisoned update. This refers to a supply chain attack where attackers compromise a legitimate software update mechanism to distribute malware.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

5) C — Implement the corresponding solution: Scenario: '18k companies infected through a trusted vendor update' = supply chain (SolarWinds)....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Malicious Updates): Scenario: '18k companies infected through a trusted vendor update' = supply chain (SolarWinds).

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: SolarWinds: the classic case — 18k companies via 1 poisoned update....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Malicious Updates): SolarWinds: the classic case — 18k companies via 1 poisoned update.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: Defense: code signing + verification of update origin....

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Malicious Updates): Defense: code signing + verification of update origin.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

8) B — Implement the corresponding solution: 'software update distributes malware' = supply chain attack / poisoned update....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Malicious Updates): 'software update distributes malware' = supply chain attack / poisoned update.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual

accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) C — Implement the corresponding solution: Scenario: '18k companies infected through a trusted vendor update' = supply chain (SolarWinds)..

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Malicious Updates): Scenario: '18k companies infected through a trusted vendor update' = supply chain (SolarWinds). This highlights the risk of supply chain attacks where a trusted vendor's update mechanism is compromised, as in the SolarWinds incident. The best recommendation is to implement supply chain risk management controls, such as vendor due diligence, code signing verification, and monitoring for anomalous updates.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user behavior, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

10) B — Implement the corresponding solution: SolarWinds: the classic case — 18k companies via 1 poisoned update.

✓ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 2.3 (Malicious Updates): SolarWinds: the classic case — 18k companies via 1 poisoned update. This highlights the risk of supply chain attacks through compromised software updates.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.